

1. Phishing Email Investigation Report

2. Incident Summary

A suspicious email was analyzed as part of a phishing email investigation. The investigation focused on the sender information, email headers, suspicious URLs, IP address, and attachment.

Several indicators were identified that are consistent with a phishing attempt, including a lookalike domain, a mismatch between the sender and Reply-To addresses, a suspicious URL, and an executable attachment disguised with a double file extension.

The identified indicators of compromise (IOCs) were documented for further investigation and threat-intelligence verification.

3. Sender and Domain Analysis

Sender: security-alert@paypa1-secure-verify.com

Sender Domain: paypa1-secure-verify.com

Reply-To: paypal-support-case@mail-response-center.com

The sender domain uses a lookalike naming technique. The domain paypa1-secure-verify.com resembles the legitimate PayPal brand name but uses the number 1 in place of the letter l.

The Reply-To address also uses a different domain from the sender address:

mail-response-center.com

The difference between the sender domain and Reply-To domain is a suspicious characteristic and should be treated as an indicator for further investigation.

4. URL Analysis

Observed URL:

hxxp://paypa1-secure-verify[.]com.account-confirm[.]info/...

The URL was identified as suspicious based on its domain structure and use of an unrelated account-confirm.info domain.

The URL has been defanged using hxxp and [.] notation to prevent accidental navigation.

The URL should not be opened directly on a production system. It should instead be analyzed using approved security and threat-intelligence tools in a controlled environment.

5. Header/IP Analysis

Observed IP Address:

185.220.101.47

The IP address was identified from the Received header of the email and documented as an IOC.

Email headers provide information about the path taken by an email and can help investigators identify suspicious infrastructure. The identified IP should be further verified using approved threat-intelligence sources and correlated with other indicators from the investigation.

6. Attachment Analysis

Attachment: Account_Statement.pdf.exe

Type: application/octet-stream

Observed Extension: .exe

Assessment: Suspicious double-extension filename

The attachment uses a double-extension naming technique, Account_Statement.pdf.exe, which can make an executable file appear to be a PDF document at first glance.

The .exe extension indicates that the file is an executable Windows program. The attachment should not be opened or executed on a normal workstation.

The attachment should be analyzed in an isolated environment using appropriate malware-analysis and threat-intelligence tools.

7. IOC Summary

IOC Type	Indicator	Evidence
Sender	security-alert@paypa1-secure-verify.com	From header
Domain	paypa1-secure-verify.com	Lookalike domain
Reply-To	paypal-support-case@mail-response-center.com	Different domain
URL	hxxp://paypa1-secure-verify[.]com.account-confirm[.]info/...	Email body
IP	185.220.101.47	Received header
Attachment	Account_Statement.pdf.exe	MIME attachment

These indicators were collected from the email headers, email body, and attachment information and should be retained for further investigation and correlation.

8. Phishing Indicators

The following characteristics were identified during the investigation:

1. Lookalike Domain

paypa1-secure-verify.com uses the number 1 instead of the letter l, making the domain resemble a trusted brand.

2. **Sender/Reply-To Mismatch**

The sender and Reply-To addresses use different domains.

3. **Suspicious URL**

The URL contains an unrelated account-confirm.info domain.

4. **Double Extension**

The attachment is named Account_Statement.pdf.exe, which disguises an executable file using a PDF-like filename.

5. **Executable Attachment**

The attachment has an .exe extension and should be treated as potentially dangerous.

6. **Suspicious IP Address**

The IP address 185.220.101.47 was observed in the Received header and was recorded as an IOC.

7. **Unexpected Attachment**

The email contains an unexpected account-statement executable attachment.

These indicators, when considered together, provide multiple reasons to treat the email as suspicious and require further investigation.

9. MITRE ATT&CK Mapping

The observed phishing characteristics can be mapped to relevant MITRE ATT&CK techniques.

T1566.001 – Phishing: Spearphishing Attachment

The email contains an attachment named Account_Statement.pdf.exe. The attachment is presented as an account statement but uses an executable .exe extension.

T1566.002 – Phishing: Spearphishing Link

The email contains a suspicious URL:

hxxp://paypa1-secure-verify[.]com.account-confirm[.]info/...

The URL may be intended to direct a recipient to a fraudulent or malicious destination.

These mappings describe the observed phishing techniques and should be treated as documentation of the investigation evidence.

10. Recommended Remediation

The following actions are recommended:

- Do not open or execute the Account_Statement.pdf.exe attachment.
- Do not click or browse to the suspicious URL.
- Report the suspicious email to the organization's security or IT team.
- Quarantine or remove the phishing email from affected mailboxes.

- Block confirmed malicious domains, URLs, and IP addresses where appropriate.
- Scan potentially affected endpoints for malware.
- Review email and endpoint logs for related activity.
- Check whether any users clicked the suspicious URL or opened the attachment.
- If credentials were entered into a suspicious website, reset the affected credentials and review account activity.
- Monitor the identified IOCs for additional related activity.

11. Conclusion

The investigation identified multiple suspicious characteristics within the analyzed email, including a lookalike sender domain, a different Reply-To domain, a suspicious URL, an IP address identified in the email headers, and an executable attachment using a double-extension filename.

The identified IOCs and phishing indicators have been documented for security investigation and threat-intelligence verification. The email and attachment should be treated as suspicious, and the recommended remediation steps should be followed.